

【中间件安全】Tomcat 安全加固规范 - 微信公众号Bypass

版权声明：本文由Bypass原创发布，转载请保留出处。欢迎关注我的个人微信公众号：Bypass--，浏览更多精彩文章。 https://blog.csdn.net/qq_23936389/article/details/85013922

1. 适用情况

适用于使用Tomcat进行部署的Web网站。

2. 技能要求

熟悉Tomcat配置操作，能够利用Tomcat进行建站，并能针对站点使用Tomcat进行安全加固。

3. 前置条件

1、根据站点开放端口，进程ID，进程名称，确认站点采用Tomcat进行部署；

2、找到Tomcat路径：

方法一：开始->所有程序->Apache Tomcat->打开文件位置

方法二：window直接搜索Tomcat

方法三：[任务管理器](#)->进程-> tomcat进程->打开文件位置

方法四：D盾->工具->进程查看-> tomcat进程->打开文件位置

方法五：适用linux：切换到根路径，搜索find -name *.jsp -print（方法同样适用 查找网站根目录）

4. 详细操作

注意：建议实施项需要检查，询问管理员后方可配置，建议让管理员自行配置，实施项为必做加固项。Tomcat控制台必须确定是否对外开放，是否有远程管理权限账号：1、mageger文件夹是否存在；2、tomcat账号是否可登陆。

4.1 Tomcat控制台用户配置

备份配置文件，修改tomcat/conf/tomcat-user.xml配置文件，将账号进行注释，

若业务系统需要使用tomcat管理后台进行业务代码发布和管理，建议修改默认admin用户，且密码长度不低于10位，必须包含大写字母、特殊符号、数字组合，如下：

```
<?xml version='1.0' encoding='cp936'?>

<tomcat-users>
<!--
  <role rolename="tomcat"/>
  <role rolename="role1"/>
  <user username="tomcat" password="tomcat" roles="tomcat"/>
  <user username="both" password="tomcat" roles="tomcat,role1"/>
  <user username="role1" password="tomcat" roles="role1"/>
-->

<role rolename="manager-gui"/>
<user username="admin" password="ABCabc123!" roles="manager-gui"/>

</tomcat-users>
```

4.2 日志审计

备份配置文件，参考配置操作

编辑tomcat/conf/server.xml配置文件，在标签中增加记录日志功能

将以下内容的注释标记取消

```
<valve classname="org.apache.catalina.valves.AccessLogValve" Directory="logs"
prefix="localhost_access_log." suffix=".txt" Pattern="common" resolveHosts="false" />
```

4.3 自定义404错误页面

(1) 在网站根目录新建noFile.htm文件

(2) 查看并启用tomcat/conf/web.xml文件中下列代码:

```
<error-page>

<error-code>404</error-code>

<location>/noFile.htm</location>

</error-page>
```

4.4 最佳经验实践

因tomcat配置不当，可能导致的安全问题，常见安全漏洞如：目录浏览、webdav等

4.4.1 关闭目录浏览

(1) 编辑tomcat/conf/web.xml配置文件，

```
<init-param>

<param-name>listings</param-name>
```

```
<param-value>true</param-value>
```

```
</init-param>
```

把true改成false

(2)重新启动tomcat服务

4.4.2 使用安全的HTTP请求

编辑tomcat/conf/web.xml配置文件，添加或修改文件如下所示：

```
<security-constraint>

  <web-resource-collection>

    <url-pattern>/*</url-pattern>

    <http-method>PUT</http-method>

    <http-method>DELETE</http-method>

    <http-method>OPTIONS</http-method>

    <http-method>TRACE</http-method>

  </web-resource-collection>

  <auth-constraint>

</auth-constraint>

</security-constraint>

<login-config>

  <auth-method>BASIC</auth-method>

</login-config>
```

4.4.3 限制IP访问

打开tomcat/conf/server.xml，添加下面一行，重启[服务器](#)即可：<value
className="org.apache.catalina.values.RemoteAddrValue" allow="127.0.0.1" deny="" />

此行放在</Host>之前，只允许本地访问。

例如：

1. 只允许192.168.1.1访问：

```
<value className="org.apache.catalina.values.RemoteAddrValue" allow="192.168.1.1" deny="" />
```

1. 只允许192.168.1.0/24访问

```
<value className="org.apache.catalina.values.RemoteAddrValue" allow="192.168.1.*" deny="" />
```

4.4.4 登陆超时退出

备份配置文件，参考配置操作

编辑tomcat/conf/server.xml配置文件，修改超时时间为300秒

```
<Connector port="8080" maxHttpHeadSize="25" maxSpareThreads="75" enableLookups="false"
redirectPort="8443" acceptCount="100" connectionTimeout="300" disableUploadTimeout="true" />
```

4.5 风险操作项

4.5.1 更改默认端口

(1) 修改tomcat/conf/server.xml 配置文件，更改默认管理端口到8888

```
<Connector
```

```
port="8888" maxHttpHeaderSize="8192" maxThreads="150"
```

```
minSpareThreads="25" maxSpareThreads="75"、
```

```
enableLookups="false" redirectPort="8443" acceptCount="100"
```

```
connectionTimeout="300" disableUploadTimeout="true" />
```

(2) 重启 tomcat 服务

4.5.2 补丁更新

根据tomcat版本漏洞库查询是否存在漏洞，如果存在漏洞请在<http://httpd.apache.org>下载最新稳定版安装

最后

欢迎关注个人[微信公众号](#)：Bypass--，每周原创一篇技术干货。

